JSON ვებ ხელმოწერის (JWS) განხორციელების სახელმძღვანელო ღია ფინანსების სისტემაში

ვერსია 0.5.RC1

1 სარჩევი

2 დოკუმენტის შესახებ 4

3 დოკუმენტის ისტორია 4

4 ტერმინთა განმარტება 5

5 JWS განხორციელება HTTP მოთხოვნასა და პასუხზე 5

5.1 ხელმოწერისა და ჰეშირების დასაშვები ალგორითმები 7

5.2 მოთხოვნისა და პასუხის ტანის კოდირებისა და შეკუმშვის გამოყენების წესი 7

6 JWS დაცული თავსართის ველები 8

7 HTTP თავსართები 12

7.1 თავსართების მნიშვნელობებზე ხელმოწერის წესი 13

8 ხელმოწერის შემოწმებასთან დაკავშირებული მოთხოვნები 13

8.1 ხელმოწერის სერტიფიკატის იდენტიფიკაცია 14

8.2 სერტიფიკატის გამცემი დასაშვები ორგანოების სია 14

8.3 ხელმოწერის სერტიფიკატის სანდოობის დადგენა 14

9 HTTP შეტყობინება JWS ხელმოწერის განხორციელება (ინფორმაციული) 15

9.1 HTTP შეტყობინება, რომელსაც უნდა მოეწეროს ხელი 15

9.2 JWS დაცული თავსართის შექმნა 16

9.3 JWS დაცული თავსართის გადაყვანაBase64url ფორმატში 17

9.4 HTTP ტანის ჰეშის გენერირება 17

9.5 HTTP თავსართების შეგროვება ხელმოსაწერად 18

9.6 მონაცემების მომზადება ხელმოწერის განსახორციელებლად 18

9.7 JWS ხელმოწერის მნიშვნელობის გამოთვლა 19

9.8 JWS ხელმოწერის აწყობა 19

9.9 JWS ხელმოწერილი HTTP შეტყობინების გენერირება 19

10 HTTP შეტყობინებაზე JWS ხელმოწერის შემოწმება (ინფორმაციული) 20

10.1 შემომავალი, JWS ხელმოწერილი HTTP შეტყობინება 21

10.2 JWS დაცული თავსართის განცალკევება HTTP შეტყობინებადან და გადაყვანა Base64 ფორმატიდან JSON ფორმატში 21

10.3 HTTP თავსართების განცალკევება HTTP შეტყობინებადან JWS დაცული თავსართის მიხედვით 22

10.4 იმ მონაცემების აღდგენა რომელიც იყო ხელმოწერილი 23

10.5 HTTP შეტყობინებაში გადმოცემული JWS ხელმოწერის მნიშვნელობის შემოწმება 23

10.6 HTTP ტანის ჰეშის შედარება HTTP შეტყობინებაში გადმოცემულ მნიშვნელობასთან 24

10.7 სერტიფიკატის სისწორის შემოწმება 24
11 ბიბლიოგრაფია 25

2 დოკუმენტის შესახებ

ეს დოკუმენტი წარმოადგენს მხოლოდ სახელმძღვანელოს და მისი მიზანია ხელი შეუწყოს ღია ბანკების მიზნებისთვის ელექტრონული ხელმოწერების განხორციელების დანერგვას JSON Web Signature (JWS) გამოყენებით. JWS ხელმოწერა წარმოადგენს API მოთხოვნებზე და პასუხებზე ელექტრონულად ხელის მოწერის მექანიზმს JSON ფორმატზე დაფუძნებული სტრუქტურით.

JWS მიზანია, უზრუნველყოს ინფორმაციის დაცულად მიმოცვლა ამსპ-ებსა და მმპ-ებს შორის HTTP მოთხოვნებზე და პასუხებზე JWS ხელმოწერის დატანის საშუალებით და JWS კრიპტოგრაფიული მექანიზმების გამოყენებით.

აღნიშნული დოკუმენტი სრულად შეესაბამება (1)-თან და (2)-თან. აზუსტებს მათ მოთხოვნებს ადგილობრივი კონტექსტის გათვალისწინებით. დოკუმენტში რაიმე შეუსაბამობის პოვნის შემთხვევაში გთხოვთ მოგვწეროთ obstandards@association.ge

გასაღები სიტყვების ქართული თარგმანების ინტერპრეტაცია უნდა მოხდეს (3)-ის მე-2 თავის შესაბამისად.

3 დოკუმენტის ისტორია

ვერსია	თარიღი	ცვლილება
0.2	15.02.2021	საწყისი ვერსია.
0.3	16.03.2021	HTTP თავსართი-ის ველები და JWS დაცული თავსართის ველებში დაემატა მნიშვნელობები და გახდა უფრო დეტალური, ასევე აისახა კომერციული ბანკების კომენტარები.
0.4	28.05.2021	დაზუსტდა დოკუმენტის სახელი, ასევე ხელმოწერის ობიექტში ველების სავალდებულობის საკითხი. გაქართულდა ზოგი ტერმინი.
0.5		დაზუსტდა მოთხოვნები JWS დაცულ თავსართებთან დაკავშირებით, დაემატა HTTP თავსართებზე ხელმოწერის წესი, მათ შორის მათ შორის გამყოფი სიმბოლოების საკითხი

შენიშვნა: შესაძლოა დოკუმენტს ჰქონდეს მე-3 დონის ვერსიები (მაგ. 0.8.RC1), რაც მითითებული იქნება სათაურის ქვემოთ. აღნიშნული მიდგომა გამოიყენება იმ შემთხვევაში, როდესაც ვერსია ჯერ კიდევ არაა საბოლოო და მასში შეიძება შევიდეს სარედაქციო ან/და სხვა ნაკლებად მნიშვნელოვანი შესწორებები. როდესაც ვერსიაზე მუშაობა დასრულდება, მე-3 დონის ვერსია მოიხსნება (ანუ, 0.8.RC1, 0.8.RC2, ...0.8.RCn საბოლოოდ გადაიქცევა 0.8 ვერსიად).

4 ტერმინთა განმარტება

- JWS (JSON Web Signature) - მოთხოვნაზე ან პასუხზე ციფრული ხელმოწერა JSON ფორმატზე დაფუძნებული მონაცემთა სტრუქტურით.

- JWS დაცული თავსართი (JWS Protected Header) – JSON ფორმატზე დაფუძნებული ობიექტი რომელიც შეიცავს სათაურის პარამეტრებს და განსაზღვრავს რა პრინციპით უნდა განხორციელდეს JWS ხელმოწერა. მაგალითი შეგიძლიათ იხილოთ ამ დოკუმენტის 9.2 თავში.

- JWS Payload - JWS სასარგებლო ტვირთი რომელსაც უნდა იყო დაცული JWS ხელმოწერის საშუალებით.

- JWS Signature Value – ციფრული ხელმოწერის კრიპტოგრაფიული მნიშვნელობა.

- HTTP - ჰიპერტექსტის გადაცემის პროტოკოლი (4) შესაბამისად.

- HTTP Body - მოთხოვნისა და პასუხის სასარგებლო ტვირთის ტანი რომელიც გადაცემულია HTTP პროტოკოლის საშუალებით (4) შესაბამისად.

- HTTP თავსართი - მოთხოვნისა და პასუხის სასარგებლო ტვირთის სათაური რომელიც გადაცემულია HTTP პროტოკოლის საშუალებით (4) შესაბამისად.

5 JWS განხორციელება HTTP მოთხოვნასა და პასუხზე

აუცილებელია, HTTP მოთხოვნებზე და პასუხებზე, რომელიც შეეხება API-ის გამოძახებას განხორციელდეს JWS ხელმოწერა.

აუცილებელია, JWS ხელმოწერით იქნას დაცული როგორც HTTP თავსართი-ის ველები ასევე HTTP Body-ში შემავალი ინფორმაცია.

აუცილებელია, Json სტრუქტურა გადაყვანილი იქნას BASE64URL ფორმატში (2) დოკუმენტის 7 თავის შესაბამისად.

აუცილებელია, ჰეშ-კოდის გამოთვლისას და ხელმოწერის შექმნისას როგორც ამსმპ-მ ისე მმპ-მ გამოიყენოს მხოლოდ ის ალგორითმები, რაც (2) სტანდარტითაა დაშვებული.

აუცილებელია, JWS ხელმოწერის განხორციელების დროს დაფარული უნდა იყოს JWS სტრუქტურის ველები ამ დოკუმენტის 6 თავის შესაბამისად.

აუცილებელია, JWS ხელმოწერის განხორციელების დროს დაფარული უნდა იყოს HTTP თავსართი ველები ამ დოკუმენტის 7 თავის შესაბამისად.

ხელმომწერმა მხარემ **არავითარ შემთხვევაში** არ უნდა გამოიყენოს დროის კვალიფიციური აღნიშვნა, ვინაიდან ეს, ერთი მხრივ, ზრდის შეტყობინების ხელმომწერის დამოკიდებულებას გარე სერვისებზე და, მეორე მხრივ, შეტყობინების მიმღებს აიძულებს გადაამოწმოს დროის კვალიფიციური აღნიშვნის სისწორე.

აუცილებელია, ხელმოწერის შექმნის თარიღის და დროის მისათითებლად გამოყენებული JWS დაცული თავსართის "sigT" ველი. ხელმოწერის შემმოწმებელმა მხარემ **არავითარ შემთხვევაში** არ უნდა მიიჩნიოს ხელმოწერის შექმნის თარიღად HTTP თავსართი-ის "Date" ველის მნიშვნელობა.

აუცილებელია, სისტემის ყველა მონაწილე (ამსმპ და მმპ) ახდენდეს დროის სინქრონიზაციას საერთაშორისო კოორდინირებულ დროსთან (UTC).

აუცილებელია, სისტემის ყველა მონაწილემ (ამსმპ-მა და მმპ-მა) შეამოწმოს მიღებულ შეტყობინებებში არსებული თარიღის ველის მნიშვნელობა ("sigT") შეტყობინების დამუშავებამდე და შეადაროს საკუთარ სისტემაში დაფიქსირებულ დროს. იმ შემთხვევაში, თუ მიღებულ შეტყობინებაში დაფიქსირებული დრო უფრო მეტია, ვიდრე თავად მონაწილის სისტემაში დაფიქსირებული დრო და აღნიშნული სხვაობა 2 (ორ) წამს აღემატება ან თუ მიღებულ შეტყობინებაში დაფიქსირებული დრო უფრო ნაკლებია ვიდრე თავად მონაწილის სიტემაში დაფიქსირებული დრო და აღნიშნული დრო აღემატება 60 წამს, მოქმედებს შემდეგი წესი, შეტყობინება **არავითარ შემთხვევაში** არ უნდა დამუშავდეს, თუ საქართველოს ეროვნული ბანკის მიერ სხვა რამ არ არის დადგენილი.

თუ JWS დაცულ თავსართში გამოყენებულია x5c ველი, **არავითარ შემთხვევაში** არ უნდა იქნას გამოყენებული x5t#S256 ან პირიქით. ვინაიდან (1) შესაბამისად იკრძალება ზემოხსენებული ორი პარამეტრის ერთდროულად გამოყენება.

შესაძლოა, გამოყენებული იქნას ერთიდაიგივე სახელის მქონე HTTP თავსართი -ები (5)-ის 3.2.2 თავის შესაბამისად და წინამდებარე დოკუმენტი არ აწესებს რაიმე სახის დამატებით შეზღუდვას აღნიშნულზე. ამდენად, როგორც ამსმპ ისე მმპ მზად უნდა იყვნენ აღნიშნულისათვის.

აუცილებელია, JWS დაცული თავსართის გენერირების დროს გამოყენებული იყოს ნუსხური სიმბოლოები.
აუცილებელია, JWS დაცული თავსართი დაგენერირდეს ერთ ხაზოვან ტექსტად, ახალ ხაზზე გადასვლის და ზედმეტი „ჰარი"-ების გარეშე. ასევე არ უნდა იყოს გამოყენებული "Escape"

სიმბოლოები. JWS დაცული თავსართის ველები დეტალურად არის აღწერილი ამ დოკუმენტის 6 თავში.

აუცილებელია, ყურადღება მიექცეს JWS დაცული თავსართის სათაურის პარამეტრში "pars"-ში განთავსებულ HTTP თავსართების თანმიმდევრობას. კერძოდ ისინი უნდა იყვნენ ზუსტად იმ თანმიმდევრობით განლაგებული რა თანმიმდევრობითაც მოხდება მათი დალაგება ჰეშირებისათვის 9.5 თავში.
აუცილებელია, JWS დაცული თავსართის Base64url მნიშვნელობის შემდეგ დაისვას "." (წერტილი), რომელიც გამოიყენება გამომყოფად JWS დაცული თავსართის Base64url ფორმატში გადაყვანის შედეგსა და HTTP თავსართებს შორის (2)-ის 3.1 თავის შესაბამისად .

5.1 ხელმოწერისა და ჰეშირების დასაშვები ალგორითმები

აუცილებელია, JWS დაცული თავსართის alg ველში და HTTP ტანის ჰეშის დასაგენერირებლად გამოყენებული იყოს მხოლოდ ის ალგორითმები რაც მხარდაჭერილი არის (1) და (6)-ით. ასევე **აუცილებელია** თითოეულ ამსმპ-ს და მმპმ-მ მხარი დაუჭირონ არანაკლებ შემდეგ ხელმოწერის ალგორითმებს RS256, RS512, ES256, ES512, PS256, PS512 და ჰეშირების ალგორითმებს SHA-256 და SHA-512

არავითარ შემთხვევაში არ უნდა იყოს გამოყენებული alg ველის მნიშვნელობა „none".

რეკომენდებულია, HTTP ტანის ჰეშის გენერირების დროს გამოყენებული იყოს ჰეშირების იგივე ალგორითმი, რაც გამოიყენება JWS დაცული თავსართის „alg" ველი მითითებულ ხელმოწერის ალგორითმში.

5.2 მოთხოვნისა და პასუხის ტანის კოდირებისა და შეკუმშვის გამოყენების წესი

აუცილებელია, მმპ-მ მოთხოვნაში Accept-Encoding სათაურის გამოყენების საკითხი გადაჭრას ერთ-ერთი შემდეგი მოთხოვნის შესაბამისად:

1) არ გამოიყენოს Accept-Encoding სათაური - ამ შემთხვევაში **აუცილებელია** ამსმპ-მ ჩათვალოს, რომ მმპ მხარს არ უჭერს მოთხოვნისა და ტანის კოდირებას და შეკუმშვას (ანუ იგივე, რაც Accept-Encoding=identity)
2) Accept-Encoding ააწყოს და გადასცეს იმგვარად, რომ დასაშვებ მეთოდებს შორის ცხადად ან არაცხადად მონაწილეობდეს identity პარამეტრი (ანუ თუ identity მითითებულია, q=0 **არავითარ შემთხვევაში** არ უნდა იყოს გამოყენებული). ამსმპ-ს უფლება აქვს, უპირატესობა მიანიჭოს identity მეთოდს, მიუხედავად იმისა რა პრიორიტეტით გადასცემს მას ამსმპ
3) იმოქმედოს ამსმპ-სთან ორმხრივი ან მრავალმხრივი ხელშეკრულების შესაბამისად, ასეთის არსებობის შემთხვევაში

მმპ-ს მხრიდან ზემოაღნიშნული მოთხოვნის შეთანხმების შეუსრულებლობისას (მათ შორის კოდირების/შეკუმშვის შეუთანხმებელი მეთოდის გამოყენებისას) **უმჯობესია**, ამსმპ-მა უარი განაცხადოს მოთხოვნის დამუშავებაზე და დააბრუნოს HTTP შეცდომა 400 Bad Request.

აუცილებელია, ამსმპ-მა პასუხი დააბრუნოს შეკუმშვისა და კოდირების ისეთი მეთოდი, რომელიც მმპ-ს მიერ არის მხარდაჭერილი.

აუცილებელია, მმპ-მა ხელმოწერა განახორციელოს მოთხოვნის ტანზე შეკუმშვისა და კოდირების გარეშე. მმპ-მ არავითარ შემთხვევაში არ უნდა გადასცეს Content-Encoding მნიშვნელობა JWS დაცული თავსართის pars ველში.

შესაძლოა, ამსმპ-მა ხელი მოაწეროს უკვე შეკუმშულ/კოდირებულ ტანს (მაგ. იმ შემთხვევაში, თუ მას პასუხი კეშირებული აქვს). თუმცა ამ შემთხვევაში **აუცილებელია**, ამსმპ-მა JWS დაცული თავსართის pars ველში სათაურების დასახელებებს შორის მიუთითოს "Content-Encoding" (რათა მმპ-მ ნათლად გაიგოს, რა მონაცემზე მოეწერა ხელი). თუ ამსმპ ხელს აწერს შეუკუმშავ და არაკოდირებულ ტანს, მან **არავითარ შემთხვევაში** არ უნდა ჩაწეროს pars ველში არსებულ ჩამონათვალში „Content-Encoding".

6 JWS დაცული თავსართის ველები

დასახელება	გამოყენების სტატუსი	რომელი სტანდარტით არის დარეგულირებული	აღწერა
b64	**აუცილებელია**	(1) (7)	ველი ლოგიკური ტიპისაა • false მნიშვნელობა მიუთითებს რომ სასარგებლო ტვირთი, ხელმოწერის ჩათვლით, გადაყვანილია base64url-encode კოდირებაში • true მნიშვენელობა მიუთითებს, რომ სასარგებლო ტვირთი წარმოდგენილია კოდირების გარეშე. ამ დოკუმენტთან თავსებადობის მიზნით **აუცილებელია** მნიშვნელობა იყოს false.
alg	**აუცილებელია**	(2) (1) (8)	ელექტრონული ხელმოწერის ალგორითმი, რომელიც გამოიყენება სასარგებლო

			ტვირთის ელექტრონული ხელმოწერისათვის. **აუცილებელია** გამოყენებული იქნას მხოლოდ ის ალგორითმები, რომლებიც მითითებულია (9)-ში.
jku	**შესაძლოა**	(1)	ელექტრონული ხელმოწერის სერტიფიკატი, რომლითაც შესაძლებელია ხელმოწერის უტყუარობის დადგენა. **შესაძლოა**, ეს ველი მითითებული იყოს JWS დაცულ თავსართში, თუმცა ხელმოწერის მიმღებმა მხარემ **არავითარ შემთხვევაში** არ უნდა დაავალდებულოს ხელმომწერი მხარე, შეავსოს იგი - გარდა 8.1 თავით განსაზღვრული შემთხვევისა
jwk	**არავითარ შემთხვევაში**	(1)	ელექტრონული ხელმოწერის ღია გასაღები, რომლითაც შესაძლებელია ხელმოწერის უტყუარობის დადგენა.
kid	**შესაძლოა**	(1)	**შესაძლოა**, ეს ველი მითითებული იყოს JWS დაცულ თავსართში, თუმცა ხელმოწერის მიმღებმა მხარემ **არავითარ შემთხვევაში** არ უნდა დაავალდებულოს ხელმომწერი მხარე, შეავსოს იგი - გარდა 8.1 თავით განსაზღვრული შემთხვევისა
x5u	**პირობითი**	(1)	ელექტრონული მისამართი (URI), სადაც განთავსებულია ელექტრონული ხელმოწერის სერტიფიკატი ან სერტიფიკატების ჯაჭვი. **შესაძლოა**, აღნიშნული ველი მითითებული იყოს JWS დაცულ თავსართში, თუმცა ხელმოწერის მიმღებმა მხარემ ამაზე **არავითარ შემთხვევაში** არ უნდა

			დაავალდებულოს ხელმომწერი მხარე, გარდა 8.1 თავით განსაზღვრული შემთხვევისა. აღნიშნული ველის გამოყენება **აუცილებელია** 8.3 თავით განსაზღვრულ შემთხვევაში (როდესაც გამოიყენება სერტიფიკატის გამცემი შუალედური ორგანოები)
x5c	**აუცილებელია**	(1)	x.509 სერტიფიკატის ღია გასაღები, რომელიც შეესაბამება იმ გასაღებს რომლითაც განხორციელებული იქნა JWS ხელმოწერა. გარდა 8.1 თავით განსაზღვრული შემთხვევისა, **აუცილებელია**, აღნიშნული ველი მითითებული იყოს JWS დაცულ თავსართში და **აუცილებელია** იგი შეიცავდეს ერთადერთ ჩანაწერს, უშუალოდ ხელმოწერის სერტიფიკატს.
x5t	**არავითარ შემთხვევაში**	(1)	x.509 ხელმოწერის სერტიფიკატის SHA-1 ჰეში
x5t#S256	**შესაძლოა**	(1)	ელექტრონული ხელმოწერის სერტიფიკატის SHA-256 ჰეში.
typ	**არარეკომენდებულია**	(1)	**შესაძლოა**, ეს ველი მითითებული იყოს JWS დაცულ თავსართში. ამ შემთხვევაში **რეკომენდებულია** მისი მნიშვნელობა იყოს JOSE. ზოგიერთი პროგრამული ბიბლიოთეკა ამ ველში წერს მნიშვნელობას jose (ნუსხური ასოებით), რაც არ არის თავსებადი (1)-თან და, მაშასადამე ამ დოკუმენტთანაც. აქედან გამომდინარე, ამ ველის გამოყენება ამ დოკუმენტის მიმდინარე ვერსიაში **არარეკომენდებულია**.

cty	**არავითარ შემთხვევაში**	(1)	აღწერა იხილეთ (2) დოკუმენტის 4.1.10 თავში.
crit	**აუცილებელია**	(1)	JWS დაცული თავსართის კრიტიკული ველების სია
sigT	**აუცილებელია**	(1) (2) (10)	განსაზღვრავს JWS ხელმოწერის დროს და **აუცილებელია** ასახავდეს ტრანზაქციის განხორციელების რეალურ დროს. **აუცილებელია** JWS ხელმოწერის თარიღი უნდა შეესაბამებოდეს (10) ფორმატს იგი უნდა იყოს წამოდგენილი UTC დროით ფორმატში და **არავითარ შემთხვევაში** არ უნდა იყოს წარმოდგენილი ფრაქციული წამებით (მაგალითად, ველის სწორი მნიშვნელობაა 2019-11-19T17:28:15Z)
sigD	**აუცილებელია**	(1)	შედგენილი ობიექტი, რომელიც განსაზღვრავს ელექტრონული ხელმოწერის სხვადასხვა პარამეტრს
mId	**აუცილებელია**		URI ტიპის უნიკალური იდენტიფიკატორი, რომელიც განსაზღვრავს სათაურების (ამ შემთხვევაში HTTP სათაურების) დამუშავების ალგორითმს ხელმოწერის ჰეშის გენერაციის პროცესში. ამ დოკუმენტის მიზნებისათვის **აუცილებელია** ველი შეიცავდეს მნიშვნელობას http://uri.etsi.org/19182/HttpHeaders როგორც მითითებას HttpHeaders მექანიზმზე (11)
pars	**აუცილებელია**	(1)	იმ სათაურების სია, რომლებიც დამუშავდება “mId” ველში მითითებული ალგორითმით. ინფორმაცია მხარდაჭერილი სათაურების შესახებ მითითებულია მე-7 თავში.

7 HTTP თავსართები

შენიშვნა: ღია ბანკინგის მიზნებისათვის გამოსაყენებელი HTTP თავსართები აღწერილია (3) დოკუმენტში. ამ თავში განსაზღვრულია დამატებითი თავსართები, ხელმოწერის მიზნებისათვის.

დასახელება	დაცული უნდა იყოს თუ არა ხელმოწერით	აღწერა
Host	**აუცილებელია**	ველის აღწერა იხილეთ (5) დოკუმენტის 5.4 თავში
Content-Type	**აუცილებელია**	HTTP შიგთავსის ტიპი
Date	**არარეკომენდებულია**	HTTP შეტყობინების შექმნის თარიღი
Content-Encoding	**პირობითი**	გამოყენების საკითხები განისაზღვრება 5.2 თავით
Digest	**აუცილებელია**	HTTP ტანის ჰეში
x-jws-signature	**აუცილებელია**	JWS ხელმოწერის მნიშვნელობა
აუცილებელია, PSU-* დაწყებული ყველა HTTP თავსართი, ასევე x-request-id და ყველა სხვა HTTP თავსართი რომელის ხელმოწერაც მოთხოვნილი არის (3) მიხედვით (ასეთი თავსართის გადმოცემისა და შესაბამისი ვალდებულების არსებობის შემთხვევაში), დაცული იყოს ხელმოწერით და მისი დასახელება დამატებული იყოს JWS დაცული თავსართის “pars” მნიშვნელობაში. ორაზროვნების შემთხვევაში **აუცილებელია** გამოყენებული იქნას წინამდებარე დოკუმენტის დანაწესი.		

აუცილებელია, JWS ხელმოწერის განხორციელების დროს დაცული იყოს HTTP მოთხოვნისა და პასუხის პირველი ხაზი ელექტრონული ხელმოწერით. დეტალურად იხილეთ ქვემოთ მოცემულ ცხრილში.

დასახელება	დაცული უნდა იყოს თუ არა სერტიფიკატით	აღწერა
(request-target)	**აუცილებელია**	**აუცილებელია,** გამოყენებული იქნა მოთხოვნის ხელმოწერის დროს. აღნიშნული ველის მნიშვნელობა არის მოთხოვნის პირველი ხაზი. **არ უნდა** იქნას გამოყენებული პასუხის

		ხელმოწერის დროს. მაგალითი შეგიძლიათ იხილოთ ამ დოკუმენტის 9.1 და 9.5 თავებში
(response-status)	**აუცილებელია**	**აუცილებელია,** გამოყენებული იქნას პასუხის ხელმოწერის დროს. გამოყენებული უნდა იქნას (4) შესაბამისად. HTTP Response კოდი **არავითარ შემთხვევაში** არ უნდა იქნას გამოყენებული მოთხოვნის ხელმოწერის დროს.

7.1 თავსართების მნიშვნელობებზე ხელმოწერის წესი

უმეტესწილად, HTTP თავსართების მნიშვნელობები რეგისტრისადმი მგრძნობიარე (case sensitive) არიან. აქედან გამომდინარე, გარდა ამ დოკუმენტით მითითებული გამონაკლისებისა, **აუცილებელია**, ხელმოწერის შექმნისას (და შემოწმებისას) თავსართების მნიშვნელობები დარჩეს ხელუხლებლად.

ზემოაღნიშნული წესიდან გამონაკლისს შეადგენენ იმ თავსართების მნიშვნელობები, რომელთა შესახებ (12)-ში ცხადადაა მითითებული რომ მათი მნიშვნელობა რეგისტრისადმი მგრძნობიარეა (case insensitive). ამგვარ მნიშვნელობებზე ხელმოწერის შექმნისას **აუცილებელია**, მნიშვნელობა გადავიდეს ნუსხურში და ისე მოეწეროს ხელი მასზე. **უმჯობესია**, ამგვარი მნიშვნელობები HTTP შეტყობინებაშიც ნუსხურში იქნას გადაყვანილი.

მაგალითად, აღნიშნული მოთხოვნა ვრცელდება Content-Type თავსართზე, რომელსაც (12)-ის მიხედვით აქვს შემდეგი ფორმა:

Content-Type := type "/" subtype *[";" parameter]

parameter := attribute "=" value

- type - ტიპი (მაგ. “application") ხელმოწერისას/შემოწმებისას გადადის ნუსხურში
- subtype - ქვეტიპი (მაგ. “json”) ხელმოწერისას/შემოწმებისას გადადის ნუსხურში
- attrribute - ატრიბუტის სახელი, ხელმოწერისას/შემოწმებისას გადადის ნუსხურში
- value - ატრიბუტის მნიშვნელობა. უმეტეს შემთხვევებში აღნიშნული მნიშვნელობა რეგისტრისადმი მგრძნობიარეა, თუმცა არსებობს გამონაკლისი ატრიბუტები, შემდეგი სახელებით:
    - charset - მნიშვნელობა ხელმოწერისას/შემოწმებისას გადადის ნუსხურში
    - access-type - მნიშვნელობა ხელმოწერისას/შემოწმებისას გადადის ნუსხურში

8 ხელმოწერის შემოწმებასთან დაკავშირებული მოთხოვნები

8.1 ხელმოწერის სერტიფიკატის იდენტიფიკაცია

აუცილებელია, როგორც ამსმპ ისე მმპ მხარს უჭერდეს სერტიფიკატის იდენტიფიკაციას JWS დაცული თავსართის x5c ველის გამოყენებით.

შესაძლოა x5c ველი შეტყობინებაში ან/და პასუხში იყოს ცარიელი, თუ ამსმპ-სა და მმპ-ს შორის არსებობს შეთანხმება აღნიშნულის თაობაზე. შეთანხმების შემთხვევაში **აუცილებელია**, ამსმპ-მა და მმპ-მა გამოიყენონ სერტიფიკატის იდენტიფიკაციის ერთ-ერთი შემდეგი მეთოდი ან მათი კომბინაცია:

1) x5u
2) x5t#S256

თუ გამოიყენება x5t#S256, **აუცილებელია** JWS დაცულ თავსართში ასევე მითითებული იყოს kid ველი, რათა ხელმოწერის მიმღებმა მხარემ ხელმოწერის სერტიფიკატი უნიკალურად გაარჩიოს.

8.2 სერტიფიკატის გამცემი დასაშვები ორგანოების სია

სერტიფიკატის გამცემი დასაშვები ორგანოების (Certification Authority) სია განისაზღვრება იმ სერვისის დოკუმენტაციით, რომლის დაცულობისთვისაც გამოიყენება ხელმოწერა. ეს დოკუმენტი აღნიშნულ საკითხს დამატებით არ არეგულირებს.

შესაძლოა, სერტიფიკატის გამცემი დასაშვები ორგანო არ მოქმედებდეს თვითხელმოწერილი სერტიფიკატით.

მაგალითად: ღია ბანკინგის მიზნებისათვის საქართველოს საბანკო ასოციაციის მიერ გაცემული სერტიფიკატების შემთხვევაში სერტიფიკატის გამცემი დასაშვები ორგანო არის Banking Association OB Seal CA (რომლის სერტიფიკატი გაცემულია Banking Association Root CA -ს მიერ) და არა Banking Association Root CA (რომლის სერტიფიკატიც თვითხელმოწერილია).

შესაძლოა, ელექტრონული ხელმოწერის სერტიფიკატი გაცემული იყოს არა უშუალოდ სერტიფიკატის გამცემი დასაშვები ორგანოს, არამედ მისი დაქვემდებარებული ორგანოს (Subordinate CA) მიერ.

8.3 ხელმოწერის სერტიფიკატის სანდოობის დადგენა

თუ ხელმოწერის სერტიფიკატი გაცემულია დაქვემდებარებული ორგანოს მიერ, **აუცილებელია** JWS დაცულ თავსართში მითითებული იყოს x5u ველიც. ამ შემთხვევაში **აუცილებელია** x5u ველში მოცემულ მისამართზე არსებულ ფაილში მითითებული იყოს როგორც უშუალოდ ხელმოწერის სერტიფიკატი, ისე ყველა იმ დაქვემდებარებული ორგანოს სერტიფიკატი, რომლებიც აუცილებელია სერტიფიკატის გამცემი დასაშვები ორგანოების სიაში არსებულ სერტიფიკატამდე გზის ასაგებად. უშუალოდ დასაშვები ორგანოს სერტიფიკატის მითითება **არარეკომენდებულია**.

აუცილებელია, ხელმოწერის მიმღებმა მხარემ გადაამოწმოს, მოქმედია თუ არა სერტიფიკატი (სერტიფიკატის გამცემი ორგანოს მიერ სერტიფიკატი გაუქმებული ან შეჩერებული არ არის) და ასევე ყველა შუალედური სერტიფიკატი (ასეთის არსებობის შემთხვევაში).

9 HTTP შეტყობინება JWS ხელმოწერის განხორციელება (ინფორმაციული)

აღნიშნული თავი შეიცავს მაგალითს თუ როგორ უნდა განხორციელდეს JWS ხელმოწერა (1) და (2) შესაბამისად, რომელიც თავსებადი იქნება (3) სტანდარტთან.

აღნიშნული თავში მოცემული HTTP შეტყობინება არის HTTP Post ტიპის. გამომდინარე იქიდან რომ JWS ხელის მოწერა შესრულება ტექნიკურად არ განსხვავდება მოთხოვნისთვის და პასუხისთვის წინამდებარე თავში ნაჩვენები იქნება მხოლოდ HTTP Response ტიპის მოთხოვნაზე ხელმოწერის მაგალითი.

შენიშვნა: JWS ხელმოწერის განხორციელების მაგალითში HTTP Payload-ის ველის მნიშვნელობა სრულდება (0X0A) სიმბოლოთი ბოლო ხაზის ჩათვლით.

9.1 HTTP შეტყობინება, რომელსაც უნდა მოეწეროს ხელი

ამ თავში მოცემული HTTP შეტყობინება არის HTTP Response ტიპის, რომელიც შედგება HTTP თავსართებისა და HTTP ტანისგან და ის სრულად თავსებადია ღია ბანკინგის მიზნებისთვის.

შენიშვნა: ქვემოთ მოცემულ მაგალითში თითოეული სტრიქონი სრულდება (0x0A) სიმბოლოთი ბოლო ხაზის ჩათვლით.

```
POST /v1/payments/sepa-credit-transfers HTTP/1.1
Host: api.testbank.com
Content-Type: application/json
X-Request-ID: 99391c7e-ad88-49ec-a2ad-99ddcb1f7721
PSU-IP-Address: 192.168.8.78
PSU-GEO-Location: GEO:52.506931,13.144558
PSU-User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:54.0) Gecko/20100101
Firefox/54.0
Date: Mon, 26 Oct 2020 11:24:37 GMT
{
"instructedAmount": {"currency": "EUR", "amount": "123.50"},
"debtorAccount": {"iban": "DE40100100103307118608"},
"creditorName": "Merchant123",
"creditorAccount": {"iban": "DE02100100109307118603"},
"remittanceInformationUnstructured": "Ref Number Merchant"
}
```

9.2 JWS დაცული თავსართის შექმნა

JWS დაცული თავსართი არის JSON ფორმატზე დაფუძნებული ობიექტი რომელიც განსაზღვრავს, რა პრინციპით ხორციელდება JWS ხელმოწერა. მაგალითში არსებული ფორმატირება ნაჩვენებია ადვილად აღქმის მიზნით.

შენიშვნა: JWS დაცული თავსართი უნდა დაგენერირდეს ამ დოკუმენტის 5 თავის შესაბამისად ერთ ხაზოვან ტექსტად, ახალ ხაზზე გადასვლის და ზედმეტი „ჰარი“-ების გარეშე. ასევე არ უნდა იყოს გამოყენებული “Escape” სიმბოლოები. JWS დაცული თავსართის ველები დეტალურად არის აღწერილი ამ დოკუმენტის 6 თავში.
JWS დაცული თავსართის გენერირების დროს გამოყენებული იყოს ნუსხური სიმბოლოები ამ დოკუმენტის 5 თავის შესაბამისად

```
{
   "b64":false,
   "x5t#S256":"dytPpSkJYzhTdPXSWP7jhXgG4kCOWIWGiesdzkvNLzY",
   "crit":[
      "sigT",
      "sigD",
      "b64"
   ],
   "sigT":"2020-10-26T11:26:57Z",
   "sigD":{
      "pars":[
         "(request-target)",
         "host",
         "content-type",
         "psu-ip-address",
         "psu-geo-location",
         "digest"
      ],
      "mId":"http://uri.etsi.org/19182/HttpHeaders"
   },
   "alg":"RS256"
}
```

შენიშვნა: გამომდინარე იქიდან, რომ სერტიფიკატის ზომა რომელიც იწერება „x5c” ველში არის მოცულობით ძალიან დიდი, თვალსაჩინოებისთვის ვიყენებთ „x5t#S256“ ველს, ნაცვლად „x5c” ველისა. როგორც ამ დოკუმენტითაა მოთხოვნილი, „x5t#S256“ ველის გამოყენება დაიშვება მხოლოდ მაშინ, როდესაც მხარეებს (მპპ-სა და ამსმპ-ს) შორის არის ორმხრივი ან მრავალმხრივი შეთანხმება x5t#S256 გამოყენებაზე და აწყობილი აქვთ ერთმანეთში სერტიფიკატების უსაფრთხოდ გაცვლის პროცესი.

ყურადღება უნდა მიექცეს JWS დაცული თავსართის სათაურის პარამეტრში “pars”-ში განთავსებულ HTTP თავსართების თანმიმდევრობას ისინი უნდა დალაგდეს ამ დოკუმენტის 5 თავის შესაბამისად

9.3 JWS დაცული თავსართის გადაყვანაBase64url ფორმატში

9.2 თავის მიხედვით შექმნილი JWS დაცული თავსართის გადაყვანა Base64url ფორმატში ზედმეტი „ჰარის“,ახალ ხაზზე გადასვლის და „Escape“ სიმბოლოების გარეშე. ანუ აქვს შემდეგი სახე:

```
{"b64":false,"x5t#S256":"dytPpSkJYzhTdPXSWP7jhXgG4kCOWIWGiesdzkvNLzY","crit"
:["sigT","sigD","b64"],"sigT":"2020-10-
26T11:26:57Z","sigD":{"pars":["(request-target)","host","content-type","psu-
ip-address","psu-geo-
location","digest"],"mId":"http://uri.etsi.org/19182/HttpHeaders"},"alg":"RS
256"}
```

მისი Base64url გარდაქმნის შედეგი კი არის:

```
eyJiNjQiOmZhbHNlLCJ4NXQjUzI1NiI6ImR5dFBwU2tKWXpoVGRQWFNXUDdq
aFhnRzRrQ09XSVdHaWVzZHprdk5MelkiLCJjcml0IjpbInNpZ1QiLCJzaWdE
IiwiYjY0Il0sInNpZ1QiOiIyMDIwLTEwLTI2VDExOjI2OjU3WiIsInNpZ0Qi
OnsicGFycyI6WyIocmVxdWVzdC10YXJnZXQpIiwiaG9zdCIsImNvbnRlbnQt
dHlwZSIsInBzdS1pcC1hZGRyZXNzIiwicHN1LWdlby1sb2NhdGlvbiIsImRp
Z2VzdCJdLCJtSWQiOiJodHRwOi8vdXJpLmV0c2kub3JnLzE5MTgyL0h0dHBI
ZWFkZXJzIn0sImFsZyI6IlJTMjU2In0
```

9.4 HTTP ტანის ჰეშის გენერირება

HTTP შეტყობინებიდან HTTP Body -ის ამოღება და გადაყვანა ამ დოკუმენტით ნებადართული რომელიმე ჰეშირების ალგორითმის შესაბამისად. კერძოდ, ამ კონკრეტულ შემთხვევაში გამოვიყენებთ SHA-256 ჰეშს .

HTTP ტანის SHA-256 გადაყვანის შემდეგ მიღებული ჰეში უნდა გადავიყვანოთ Base64 ფორმატში (13) შესაბამისად.

შენიშვნა: ქვემოთ მოცემულ მაგალითში იგულისხმება რომ თითოეული სტრიქონი სრულდება (0x0A) სიმბოლოთი ბოლო ხაზის ჩათვლით, რაც გავლენას ახდენს ჰეშის მნიშვნელობაზე.

```
{
"instructedAmount": {"currency": "EUR", "amount": "123.50"},
"debtorAccount": {"iban": "DE40100100103307118608"},
"creditorName": "Merchant123",
"creditorAccount": {"iban": "DE02100100109307118603"},
"remittanceInformationUnstructured": "Ref Number Merchant"
}
```

HTTP ტანის ჰეში იწერება “Digest” ველის მნიშვნელობაში.

```
Digest: SHA-256=+xeh7JAayYPh8K13UnQCBBcniZzsyat+KDiuy8aZYdI=
```

9.5 HTTP თავსართების შეგროვება ხელმოსაწერად

HTTP თავსართები უნდა შეგროვდეს ამ დოკუმენტის 5 თავში მოთხოვნილი ფორმატით და განლაგების თანმიმდევრობით.

შენიშვნა : შეგროვებულ HTTP თავსართებს 7 თავის მოთხოვნებიდან გამომდინარე ასევე უნდა დაემატოს HTTP ტანის ჰეშის მნიშვნელობა digest ველის სახით რომელიც 9.3 თავის მიხედვით არის გამოთვლილი.

```
(request-target): post /v1/payments/sepa-credit-transfers
host: api.testbank.com
content-type: application/json
psu-ip-address: 192.168.8.78
psu-geo-location: GEO:52.506931,13.144558
digest: SHA-256=+xeh7JAayYPh8K13UnQCBBcniZzsyat+KDiuy8aZYdI=
```

აუცილებელია თავსართები შეგროვდეს ერთ სტრიქონად, შუაში გამყოფად გამოიყენებოდეს ახალ სტრიქონზე გადასვლის სიმბოლო (0x0A), როგორც ეს განსაზღვრულია (11)-ით HttpHeaders მექანიზმისათვის.

9.6 მონაცემების მომზადება ხელმოწერის განსახორციელებლად

ამ დოკუმენტის 9.3 თავში JWS დაცულ თავსართს გადაყვანილს Base64url ფორმატში ვაერთიანებთ ამ დოკუმენტის 9.4 თავში მიღებულ HTTP თავსართებს და ვამზადებთ JWS ხელმოწერისთვის.

შენიშვნა 1: ამ დოკუმენტის 5 თავის მოთხოვნის შესაბამისად აუცილებელია JWS დაცული თავსართის Base64url მნიშვნელობის შემდეგ დაისვას "." (წერტილი), რომელიც გამოიყენება გამომყოფად JWS დაცული თავსართის Base64url ფორმატში გადაყვანის შედეგსა და HTTP თავსართებს შორის (2)-ის 3.1 თავის შესაბამისად .

შენიშვნა 2: JWS დაცული თავსართის Base64url-ის მნიშვნელობის და შეგროვილი HTTP თავსართების მნიშვნელობათა გაერთიანება უნდა მოხდეს ამ დოკუმენტის 5 თავის შესაბამისად კერძოდ ისინი ერთმანეთისაგან მხოლოდ წერტილით უნდა იყოფოდნენ და არ იყოს გამოყენებული ახალ სტრიქონზე გადასვლა, „ჰარი" ან რაიმე სხვა სიმბოლო.

```
eyJiNjQiOmZhbHNlLCJ4NXQjUzI1NiI6ImR5dFBwU2tKWXpoVGRQWFNXUDdq
aFhnRzRrQ09XSVdHaWVzZHprdk5MelkiLCJjcml0IjpbInNpZ1QiLCJzaWdE
IiwiYjY0Il0sInNpZ1QiOiIyMDIwLTEwLTI2VDExOjI2OjU3WiIsInNpZ0Qi
OnsicGFycyI6WyIocmVxdWVzdC10YXJnZXQpIiwiaG9zdCIsImNvbnRlbnQt
dHlwZSIsInBzdS1pcC1hZGRyZXNzIiwicHN1LWdlby1sb2NhdGlvbiIsImRp
Z2VzdCJdLCJtSWQiOiJodHRwOi8vdXJpLmV0c2kub3JnLzE5MTgyL0h0dHBI
ZWFkZXJzIn0sImFsZyI6IlJTMjU2In0.(request-target): post /v1/payments/sepa-
credit-transfers
host: api.testbank.com
content-type: application/json
psu-ip-address: 192.168.8.78
```

```
psu-geo-location: GEO:52.506931,13.144558
digest: SHA-256=+xeh7JAayYPh8K13UnQCBBcniZzsyat+KDiuy8aZYdI=
```

9.7 JWS ხელმოწერის მნიშვნელობის გამოთვლა

JWS Signature Value კრიპტოგრაფიული მნიშვნელობის გამოთვლა ხორციელდება JWS დაცული თავსართის x5c ან x5t#S256 მითითებული სერტიფიკატის გამოყენებით და ხელმოწერის ალგორითმად გამოიყენება JWS დაცული თავსართის "alg" ველიში მითითებული ალგორითმის ხელმომოწერა.

გამოთვლილი JWS ხელმოწერის მნიშვნელობა:

```
Q9ZSYXJ0QWSoPBfBUR58Sqplw7BQcrcqVR6rvnqfBOvosbBLcsBjkjzi1kCF
2cJsHTJRtp6GcJmZplqRg-7_QBKQAgkUq0BGQpzZwhVYrvP0opdLEarVBrej
YA05gt3qnleuS53DWmyZu9iNxhwJTYVPyXediwo3TIlSn-8XjSTZAVHa728E
WK6XzRC9rEroXYPYd23iQLXetMygLaDhRT2lGhV5WvmO0wC0B6RbGiYl2zIv
D0XliMP6MidX4SDY5zlzyWyFlHqX7eHpkH8xxqAsBdKb16y4IdOoRhil9yws
vlzkG6-U9jmBU4y_m3mZArD22oRVXTywzFn9NUtY9w
```

9.8 JWS ხელმოწერის აწყობა

JWS ხელმოწერის აწყობა ხორციელდება ორ მონაცემზე დაყრდნობით კერძოდ JWS დაცული თავსართის Base64url მნიშვნელობის და JWS ხელმოწერის მნიშვნელობის გაერთიანება, რომელთაც გამყოფად გამოიყენება " . . " ორი წერტილის სიმბოლო რომლებიც ერთმანეთისგან „ჰარი"-ით არიან გამოყოფილები.

აწყობილი JWS ხელმოწერა:

```
eyJiNjQiOmZhbHNlLCJ4NXQjUzI1NiI6ImR5dFBwU2tKWXpoVGRQWFNXUDdq
aFhnRzRrQ09XSVdHaWVzZHprdk5MelkiLCJjcml0IjpbInNpZ1QiLCJzaWdE
IiwiYjY0Il0sInNpZ1QiOiIyMDIwLTEwLTI2VDExOjI2OjU3WiIsInNpZ0Qi
OnsicGFycyI6WyIocmVxdWVzdC10YXJnZXQpIiwiaG9zdCIsImNvbnRlbnQt
dHlwZSIsInBzdS1pcC1hZGRyZXNzIiwicHN1LWdlby1sb2NhdGlvbiIsImRp
Z2VzdCJdLCJtSWQiOiJodHRwOi8vdXJpLmV0c2kub3JnLzE5MTgyL0h0dHBI
ZWFkZXJzIn0sImFsZyI6IlJTMjU2In0..Q9ZSYXJ0QWSoPBfBUR58Sqplw7B
QcrcqVR6rvnqfBOvosbBLcsBjkjzi1kCF2cJsHTJRtp6GcJmZplqRg-7_QBK
QAgkUq0BGQpzZwhVYrvP0opdLEarVBrejYA05gt3qnleuS53DWmyZu9iNxhw
JTYVPyXediwo3TIlSn-8XjSTZAVHa728EWK6XzRC9rEroXYPYd23iQLXetMy
gLaDhRT2lGhV5WvmO0wC0B6RbGiYl2zIvD0XliMP6MidX4SDY5zlzyWyFlHq
X7eHpkH8xxqAsBdKb16y4IdOoRhil9ywsvlzkG6-U9jmBU4y_m3mZArD22oR
VXTywzFn9NUtY9w
```

9.9 JWS ხელმოწერილი HTTP შეტყობინების გენერირება

JWS ხელმოწერილი HTTP შეტყობინების შექმნა ხდება საწყის შეტყობინებაში ორი HTTP თავსართის დამატებით:

1) **x-jws-signature** JWS ხელმოწერა, რომელიც შეიქმნა 9.8 თავის მიხედვით.
2) Digest - HTTP ტანის ჰეში, რომელიც შეიქმნა 9.4 თავის მიხედვით.

JWS ხელმოწერილი HTTP შეტყობინება:

```
POST /v1/payments/sepa-credit-transfers HTTP/1.1
Host: api.testbank.com
Content-Type: application/json
X-Request-ID: 99391c7e-ad88-49ec-a2ad-99ddcb1f7721
PSU-IP-Address: 192.168.8.78
PSU-GEO-Location: GEO:52.506931,13.144558
PSU-User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:54.0) Gecko/20100101
Firefox/54.0
Date: Mon, 26 Oct 2020 11:24:37 GMT
Digest: SHA-256=+xeh7JAayYPh8K13UnQCBBcniZzsyat+KDiuy8aZYdI=
x-jws-signature:
eyJiNjQiOmZhbHNlLCJ4NXQjUzI1NiI6ImR5dFBwU2tKWXpoVGRQWFNXUDdqaFhnRzRrQ09XSVdH
aWVzZHprdk5MelkiLCJjcml0IjpbInNpZ1QiLCJzaWdEIiwiYjY0Il0sInNpZ1QiOiIyMDIwLTEw
LTI2VDExOjI2OjU3WiIsInNpZ0QiOnsicGFycyI6WyIocmVxdWVzdC10YXJnZXQpIiwiaG9zdCIs
ImNvbnRlbnQtdHlwZSIsInBzdS1pcC1hZGRyZXNzIiwicHN1LWdlby1sb2NhdGlvbiIsImRpZ2Vz
dCJdLCJtSWQiOiJodHRwOi8vdXJpLmV0c2kub3JnLzE5MTgyL0h0dHBIZWFkZXJzIn0sImFsZyI6
IlJTMjU2In0..Q9ZSYXJ0QWSoPBfBUR58Sqplw7BQcrcqVR6rvnqfBOvosbBLcsBjkjzi1kCF2cJ
sHTJRtp6GcJmZplqRg-
7_QBKQAgkUq0BGQpzZwhVYrvP0opdLEarVBrejYA05gt3qnleuS53DWmyZu9iNxhwJTYVPyXediw
o3TIlSn-
8XjSTZAVHa728EWK6XzRC9rEroXYPYd23iQLXetMygLaDhRT2lGhV5WvmO0wC0B6RbGiYl2zIvD0
XliMP6MidX4SDY5zlzyWyFlHqX7eHpkH8xxqAsBdKb16y4IdOoRhil9ywsvlzkG6-
U9jmBU4y_m3mZArD22oRVXTywzFn9NUtY9w
{
"instructedAmount": {"currency": "EUR", "amount": "123.50"},
"debtorAccount": {"iban": "DE40100100103307118608"},
"creditorName": "Merchant123",
"creditorAccount": {"iban": "DE02100100109307118603"},
"remittanceInformationUnstructured": "Ref Number Merchant"
}
```

10 HTTP შეტყობინებაზე JWS ხელმოწერის შემოწმება (ინფორმაციული)

აღნიშნული თავი შეიცავს მაგალითს, თუ როგორ უნდა განხორციელდეს JWS ხელმოწერის ვალიდაცია, რომელიც ხელმოწერილია (RFC7515) და (RFC7515) შესაბამისად და ასევე თავსებადი არის (3) სტანდარტთან.

აღნიშნული თავში მოცემული HTTP შეტყობინება არის HTTP Post ტიპის. გამომდინარე იქიდან, რომ JWS ხელის მოწერა შესრულება ტექნიკურად არ განსხვავდება მოთხოვნისთვის და პასუხისთვის წინამდებარე თავში ნაჩვენები იქნება მხოლოდ HTTP მოთხოვნაზე (Request) ხელისმოწერის მაგალითი.

შენიშვნა: JWS ხელმოწერის განხორციელების მაგალითში HTTP Payload -ის ველის მნიშვნელობა სრულდება (0x0A) სიმბოლოთი ბოლო ხაზის ჩათვლით.

10.1 შემომავალი, JWS ხელმოწერილი HTTP შეტყობინება

JWS ხელმოწერილი HTTP შეტყობინება:

```
POST /v1/payments/sepa-credit-transfers HTTP/1.1
Host: api.testbank.com
Content-Type: application/json
X-Request-ID: 99391c7e-ad88-49ec-a2ad-99ddcb1f7721
PSU-IP-Address: 192.168.8.78
PSU-GEO-Location: GEO:52.506931,13.144558
PSU-User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:54.0) Gecko/20100101
Firefox/54.0
Date: Mon, 26 Oct 2020 11:24:37 GMT
Digest: SHA-256=+xeh7JAayYPh8K13UnQCBBcniZzsyat+KDiuy8aZYdI=
x-jws-signature:
eyJiNjQiOmZhbHNlLCJ4NXQjUzI1NiI6ImR5dFBwU2tKWXpoVGRQWFNXUDdqaFhnRzRrQ09XSVdH
aWVzZHprdk5MelkiLCJjcml0IjpbInNpZ1QiLCJzaWdEIiwiYjY0Il0sInNpZ1QiOiIyMDIwLTEw
LTI2VDExOjI2OjU3WiIsInNpZ0QiOnsicGFycyI6WyIocmVxdWVzdC10YXJnZXQpIiwiaG9zdCIs
ImNvbnRlbnQtdHlwZSIsInBzdS1pcC1hZGRyZXNzIiwicHN1LWdlby1sb2NhdGlvbiIsImRpZ2Vz
dCJdLCJtSWQiOiJodHRwOi8vdXJpLmV0c2kub3JnLzE5MTgyL0h0dHBIZWFkZXJzIn0sImFsZyI6
IlJTMjU2In0..Q9ZSYXJ0QWSoPBfBUR58Sqplw7BQcrcqVR6rvnqfBOvosbBLcsBjkjzi1kCF2cJ
sHTJRtp6GcJmZplqRg-
7_QBKQAgkUq0BGQpzZwhVYrvP0opdLEarVBrejYA05gt3qnleuS53DWmyZu9iNxhwJTYVPyXediw
o3TIlSn-
8XjSTZAVHa728EWK6XzRC9rEroXYPYd23iQLXetMygLaDhRT2lGhV5WvmO0wC0B6RbGiYl2zIvD0
XliMP6MidX4SDY5zlzyWyFlHqX7eHpkH8xxqAsBdKb16y4IdOoRhil9ywsvlzkG6-
U9jmBU4y_m3mZArD22oRVXTywzFn9NUtY9w
{
"instructedAmount": {"currency": "EUR", "amount": "123.50"},
"debtorAccount": {"iban": "DE40100100103307118608"},
"creditorName": "Merchant123",
"creditorAccount": {"iban": "DE02100100109307118603"},
"remittanceInformationUnstructured": "Ref Number Merchant"
}
```

10.2 JWS დაცული თავსართის განცალკევება HTTP შეტყობინებადან და გადაყვანა Base64 ფორმატიდან JSON ფორმატში

JWS დაცული თავსართის ამოღება HTTP შეტყობინებიდან ხორციელდება უკუ მიმართულებით როგორც ამ დოკუმენტის 9.8 თავში JWS ხელმოწერის აწყობის განვახორციელეთ. ამ დოკუმენტის 9.8 თავის მიხედვით ვიცით, რომ JWS ხელმოწერის მნიშვნელობა ინახება x-jws-signature HTTP თავსართში, რომელიც აწყობილი არის ამ დოკუმენტის 9.7 თავის მიხედვით, კერძოდ JWS Signature Value ში " .. " სიმბოლომდე განთავსებული არის JWS დაცული სათაური.

JWS დაცული თავსართი Base64 ფორმატში:

```
eyJiNjQiOmZhbHNlLCJ4NXQjUzI1NiI6ImR5dFBwU2tKWXpoVGRQWFNXUDdq
aFhnRzRrQ09XSVdHaWVzZHprdk5MelkiLCJjcml0IjpbInNpZ1QiLCJzaWdE
IiwiYjY0Il0sInNpZ1QiOiIyMDIwLTEwLTI2VDExOjI2OjU3WiIsInNpZ0Qi
OnsicGFycyI6WyIocmVxdWVzdC10YXJnZXQpIiwiaG9zdCIsImNvbnRlbnQt
dHlwZSIsInBzdS1pcC1hZGRyZXNzIiwicHN1LWdlby1sb2NhdGlvbiIsImRp
Z2VzdCJdLCJtSWQiOiJodHRwOi8vdXJpLmV0c2kub3JnLzE5MTgyL0h0dHBI
```

```
ZWFkZXJzIn0sImFsZyI6IlJTMjU2In0
```

JWS დაცული თავსართი Base64 ფორმატიდან JSON ფორმატში გადაყვანილი (და დაფორმატებული უკეთ აღქმისთვის):

```
{
   "b64":false,
   "x5t#S256":"dytPpSkJYzhTdPXSWP7jhXgG4kCOWIWGiesdzkvNLzY",
   "crit":[
      "sigT",
      "sigD",
      "b64"
   ],
   "sigT":"2020-10-26T11:26:57Z",
   "sigD":{
      "pars":[
         "(request-target)",
         "host",
         "content-type",
         "psu-ip-address",
         "psu-geo-location",
         "digest"
      ],
      "mId":"http://uri.etsi.org/19182/HttpHeaders"
   },
   "alg":"RS256"
}
```

შენიშვნა: მაგალითში არსებული ფორმატირება ნაჩვენებია ადვილად აღქმის მიზნით.
ამ დოკუმენტის 5 თავის შესავამისად JWS დაცული თავსართი უნდა დაგენერირდეს ერთ ხაზოვან ტექსტად, ახალ ხაზზე გადასვლის და ზედმეტი “ჰარის” გარეშე ასევე არ უნდა იყოს გამოყენებული “Escape” სიმბოლოები. JWS დაცული თავსართის ველები დეტალურად არის აღწერილი ამ დოკუმენტის 6 თავში.

10.3 HTTP თავსართების განცალკევება HTTP შეტყობინებადან JWS დაცული თავსართის მიხედვით

HTTP შეტყობინებიდან ვაცალკევებთ HTTP თავსართებს ამ დოკუმენტის 10.2 თავში JWS დაცული თავსართის ”pars” ველში განთავსებული HTTP თავსართების შესაბამისად.

შენიშვნა: ველები იყვნენ დალაგებული ზუსტად იმ თანმიმდევრობით რა თანმიმდევრობითაც არის “pars” ველის მნიშვნელობაში. ასევე არ უნდა დაგვავიწყდეს რომ HTTP Payload-ის ველის მნიშვნელობა სრულდება (0X0A) სიმბოლოთი ბოლო ხაზის ჩათვლით.

HTTP თავსართები:

```
(request-target): post /v1/payments/sepa-credit-transfers
host: api.testbank.com
content-type: application/json
```

```
psu-ip-address: 192.168.8.78
psu-geo-location: GEO:52.506931,13.144558
digest: SHA-256=+xeh7JAayYPh8K13UnQCBBcniZzsyat+KDiuy8aZYdI=
```

10.4 იმ მონაცემების აღდგენა რომელიც იყო ხელმოწერილი

გამომდინარე იქიდან რომ HTTP შეტყობინების ყველა ველი ვიცით, რაც ხელმოწერისთვის იყო გამოყენებული და გვაქვს უკვე JWS დაცული თავსართიც, შეგვიძლია ახლიდან ავაწყოთ მონაცემები, რომლებზეც გამომგზავნმა ხელი მოაწერა, რათა განვახორციელოთ ხელმოწერის კრიპტოგრაფიული შემოწმება. მონაცემების აწყობა ხელმეორედ ხორციელდება ზუსტად იმ პრინციპით, რა პრინციპიც იყო გამოყენებული ამ დოკუმენტის 9.4 და 9.5 თავებში.

```
eyJiNjQiOmZhbHNlLCJ4NXQjUzI1NiI6ImR5dFBwU2tKWXpoVGRQWFNXUDdq
aFhnRzRrQ09XSVdHaWVzZHprdk5MelkiLCJjcml0IjpbInNpZ1QiLCJzaWdE
IiwiYjY0Il0sInNpZ1QiOiIyMDIwLTEwLTI2VDExOjI2OjU3WiIsInNpZ0Qi
OnsicGFycyI6WyIocmVxdWVzdC10YXJnZXQpIiwiaG9zdCIsImNvbnRlbnQt
dHlwZSIsInBzdS1pcC1hZGRyZXNzIiwicHN1LWdlby1sb2NhdGlvbiIsImRp
Z2VzdCJdLCJtSWQiOiJodHRwOi8vdXJpLmV0c2kub3JnLzE5MTgyL0h0dHBI
ZWFkZXJzIn0sImFsZyI6IlJTMjU2In0.(request-target): post /v1/payments/sepa-
credit-transfers
host: api.testbank.com
content-type: application/json
psu-ip-address: 192.168.8.78
psu-geo-location: GEO:52.506931,13.144558
digest: SHA-256=+xeh7JAayYPh8K13UnQCBBcniZzsyat+KDiuy8aZYdI=
```

10.5 HTTP შეტყობინებაში გადმოცემული JWS ხელმოწერის მნიშვნელობის შემოწმება

JWS signature value-ს ვიღებთ x-jws-signature ველიდან და ვაკეთებთ კრიპტოგრაფიულ შედარებას ამ დოკუმენტის 10.3 თავში მიღებულ მნიშვნელობასთან და ჩვენს შემთხვევაში x5t#S256 ველში გადმოცემულ სერტიფიკატზე დაყრდნობით, JWS დაცულ თავსართში “alg” ველში გადმოცემულ ალგორითმის საშუალებით.

როგორც მაგალითში მოცემულია, ხელმოწერის მნიშვნელობა არის შემდეგი:

```
Q9ZSYXJ0QWSoPBfBUR58Sqplw7BQcrcqVR6rvnqfBOvosbBLcsBjkjzi1kCF
2cJsHTJRtp6GcJmZplqRg-7_QBKQAgkUq0BGQpzZwhVYrvP0opdLEarVBrej
YA05gt3qnleuS53DWmyZu9iNxhwJTYVPyXediwo3TIlSn-8XjSTZAVHa728E
WK6XzRC9rEroXYPYd23iQLXetMygLaDhRT2lGhV5WvmO0wC0B6RbGiYl2zIv
D0XliMP6MidX4SDY5zlzyWyFlHqX7eHpkH8xxqAsBdKb16y4IdOoRhil9yws
vlzkG6-U9jmBU4y_m3mZArD22oRVXTywzFn9NUtY9w
```

ვინაიდან ხელმოწერის ალგორითმი არის RS256, რაც ნიშნავს RSASSA-PKCS1-v1_5 ხელმოწერას SHA-256 ჰეშზე დაყრდნობით. ხელმოწერის სისწორის კრიპტოგრაფიული შემოწმება უნდა მოხდეს ღია გასაღებით, რომელიც სერტიფიკატშია მითითებული.

თუ კრიპტოგრაფიული შემოწმება დაადასტურებს, რომ ხელმოწერა ნამდვილად სერტიფიკატში მითითებული ღია გასაღების შესაბამისი დახურული გასაღებითაა შექმნილი, ე.ი. HTTP თავსართში წარმოდგენილი მნიშვნელობა სწორია, ე.ი. შემოწმებამ წარმატებით გაიარა და ვიწყებთ HTTP ტანის ჰეშის შედარებას HTTP შეტყობინებაში გადმოცემულ მნიშვნელობასთან.

10.6 HTTP ტანის ჰეშის შედარება HTTP შეტყობინებაში გადმოცემულ მნიშვნელობასთან

ამ დოკუმენტის 10.3 თავის ვალიდაციის წამატებით გავლის შემდეგ ვიწყებთ HTTP ტანის ჰეშის შედარებას HTTP მესიჯში გადმოცემულ მნიშვნელობასთან. ჰეშის დადება ხორციელდება ზუსტად იმ პრინციპით, რაც იყო გამოყენებული ამ დოკუმენტის 9.3 თავში

```
{
"instructedAmount": {"currency": "EUR", "amount": "123.50"},
"debtorAccount": {"iban": "DE40100100103307118608"},
"creditorName": "Merchant123",
"creditorAccount": {"iban": "DE02100100109307118603"},
"remittanceInformationUnstructured": "Ref Number Merchant"
}
```

დაგენერირებული ჰეში:

```
Digest: SHA-256=+xeh7JAayYPh8K13UnQCBBcniZzsyat+KDiuy8aZYdI=
```

თუ დაგენერირებული ჰეში და HTTP შეტყობინებაში არსებული Digest მნიშვნელობას ედრება, **ვალიდაციამ წარმატებით გაიარა**

10.7 სერტიფიკატის სისწორის შემოწმება

ის, რომ ხელმოწერა კრიპტოგრაფიულად სწორია, კიდევ არ არის საკმარისი იმის შესამოწმებლად, რამდენად სწორად იყო განხორციელებული ხელმოწერა HTTP შეტყობინებაზე. მოხდეს იმის გადამოწმება, რამდენად სწორი სერტიფიკატი იყო გამოყენებული, უნდა განხორციელდეს (3)-ის და ასევე ამ დოკუმენტის მე-8 თავის მოთხოვნების შესაბამისად.

11 ბიბლიოგრაფია

1. **Open Banking Europe.** *JSON Web Signature Profile for Open Banking.*

2. **Jones, M., Bradley, J., and N. Sakimura.** *JSON Web Signature (JWS).* May 2015. RFC 7515.

3. **საქართველოს საბანკო ასოციაცია.** *NextGenPSD2 XS2A ჩარჩოს განხორციელების სახელმძღვანელო.* ვერსია 0.8.

4. **Fielding, R., Ed., and J. Reschke, Ed.** *Hypertext Transfer Protocol (HTTP/1.1): Semantics and Content.* June 2014. RFC 7231.

5. —. *Hypertext Transfer Protocol (HTTP/1.1): Message Syntax and Routing.* June 2014. RFC 7230.

6. **ETSI.** Electronic Signatures and Infrastructures (ESI) : Cryptographic Suites. ETSI TS 119 312.

7. **Jones, M.** *JSON Web Signature (JWS) Unencoded Payload Option.* February 2016. RFC 7797.

8. —. *Jones, M., "JSON Web Algorithms (JWA)".* RFC 7518.

9. **JSON Web Signature and Encryption Algorithms.** ***IANA, "Media Types".*** **[Online] https://www.iana.org/assignments/media-types/media-types.xhtml.**

10. Klyne, G. and C. Newman. ***Date and Time on the Internet: Timestamps.*** **July 2002. RFC 3339.**

11. ETSI. Electronic Signatures and Infrastructures (ESI); JAdES digital signatures; Part 1: Building blocks and JAdES baseline signatures. V1.1.1 (2021-03) March 2021. ETSI TS 119 182-1.

12. Borenstein, N. and N. Freed. ***MIME (Multipurpose Internet Mail Extensions): Mechanisms for Specifying and Describing the Format of Internet Message Bodies.*** **June 1992. RFC 1341.**

13. Bryan, A. ***Additional Hash Algorithms for HTTP Instance Digests.*** **April 2010. RFC 5843.**